SENTINEL · ESSECKATHON TRACK 01 · FINTECH SECURITY

Conformité

Chaque décision de paiement d'agent devient une preuve inviolable, horodatée et rejouable sur Avalanche. L'audit n'est plus déclaratif, il est vérifiable on-chain.

SentinelL1 Live | chainId 99999 | token SEC | 2026-10-11

Un contrôle = `DecisionRecorded` **Un refus** = `ThreatFlagged` **Une autorisation** = `VisaGranted` (visa à usage unique)

DORA Digital Operational Resilience Act

- Journal d'incidents inviolable : chaque block ou flag est un événement on-chain daté, une piste d'audit non répudiable (journalisation et détection des incidents TIC).
- Détection et réponse : le garde détecte (7 couches + IA) et répond (block / flag / escalade) en environ 1,4 ms (heuristiques) ou environ 3 s (fusion IA) ; un incident DORA est ouvert automatiquement au refus.
- Résilience : repli local si la chaîne est injoignable (le verdict tient), et le paiement ne passe jamais sans visa valide (fail-closed via GuardedVault).
- Reporting : métriques exportables (taux de détection, faux positifs, temps de détection et de réponse, nombre d'incidents) pour le registre d'incidents.

MICA Markets in Crypto-Assets

- Traçabilité des transferts : émetteur, bénéficiaire, montant, verdict et motif inscrits on-chain.
- Contrôle du bénéficiaire : registre de menaces on-chain et allowlist des contreparties, refus des adresses signalées (address poisoning, marchand fantôme).
- Gouvernance : décision par smart contract (AuthorityRegistry), autorités révocables, flags contestables (clearThreat, le droit de recours).

AML / CFT Travel Rule

- Qui paie qui, combien, pourquoi : attaché à chaque transaction (éléments Travel Rule).
- Détection de schémas : structuring (montant juste sous le plafond), vélocité, bénéficiaire récemment modifié, honeypot ou contrat non vérifié.
- Registre des adresses à risque : partagé on-chain, la deuxième tentative vers une adresse flaguée est refusée d'office.

KYB SOUVERAIN SOUVERAIN know your beneficiary

Couche opt-in (GUARD_KYB=on) qui vérifie le bénéficiaire contre le registre officiel des entreprises de l'État (API Recherche d'entreprises, data.gouv.fr / DINUM). Entreprise active et correspondante : preuve officielle attachée à la décision (SIREN + état). Bénéficiaire radié, introuvable ou nom non concordant : signal de risque et escalade humaine. Vérification par une source tierce officielle, loggée et rejouable (exigence DORA sur les tiers), jamais déclarative. Si le registre est indisponible, aucun paiement n'est débloqué pour autant (fail-closed via les autres couches).

AI ACT Règlement IA de l'Union européenne

- Transparence et explicabilité : chaque décision est explicable (signaux cités, poids, formule OU bruité, seuils affichés).
- Surveillance humaine : la zone de doute (30 à 70) est escaladée à un humain avant tout paiement ; sa décision est tracée.
- Robustesse : banc de tests honnête (détection 100 %, évasion 814 essais, faux positifs 0 %) et un adversaire adaptatif réel (0 bypass).
- Journalisation : enregistrement automatique des décisions (logs + on-chain) sur toute la durée de vie.
- Gestion du risque : pas d'allow deviné sans preuve, plancher humain quand l'IA est indisponible.

SEUILS DE DÉCISION · RECOMMANDATION KPMG

Confiance ≥ 70	30 à 70	Confiance < 30
Visa délivré, le paiement passe	Escalade à un humain avant tout paiement	Refus et flag de l'adresse au registre

Seuils resserrés automatiquement quand le montant approche le plafond du mandat.

PREUVES ON-CHAIN · VÉRIFIABLES PAR LE JURY

Chaîne `SentinelL1 (chainId 99999)` **AuthorityRegistry** `0x7A7e…bcb6` **GuardedVault** `0xc7de…C7c0`

Explorer `https://explorer.petroi.fr`